

Sherlock Audit Report
Project: Sample Vault
Date: 2024-03-15

Executive Summary

This is a synthetic Sherlock-style contest report used for testing.

H-1: Reentrancy in withdraw allows fund theft

Source: <https://github.com/sample/vault/blob/main/contracts/Vault.sol#L42-L60>
Severity: High

Summary: The withdraw function in target/contracts/Vault.sol:L42-L60 calls an external token before updating internal accounting state. An attacker can re-enter withdraw and drain the vault.

Recommendation: Apply the checks-effects-interactions pattern: update internal balances before the external token call. Consider adding a non-reentrancy modifier to the withdraw function.

Resolution: Fixed in commit deadbeefcafebababe1234. The team added the nonReentrant modifier and reordered the state update.

M-2: Integer overflow in fee calculation results in loss

Source: target/contracts/Fee.sol:L100
Severity: Medium

Summary: The fee calculation in target/contracts/Fee.sol:L100 multiplies two unchecked uint256 values which can overflow for large inputs.

Recommendation: Use Solidity 0.8+ checked arithmetic or SafeMath for the fee calculation. Add unit tests covering the boundary cases.

Resolution: Acknowledged. The team will address in the next release.